INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 4 Lab Assignment: Compliance Management and Reporting

Student Name: Joy Orilade
Date: 6th Feb, 2026
Instructor: Com Idris Aminu

Lab Objectives:

This lab assignment is designed to help you:

- Understand compliance management processes and documentation requirements
- Develop skills in creating compliance documentation and reports
- Apply compliance monitoring and measurement techniques
- Gain practical experience in compliance program evaluation

Instructions:

Complete all parts of this lab assignment. Submit your completed document to your instructor by the due date. All answers should be typed directly into this document.

Part 1: Compliance Documentation Development (30 points)

For this exercise, you will develop key compliance documentation for a fictional organization. Imagine you are the Compliance Officer for TechSecure Solutions, a mid-sized software development company that handles sensitive customer data and is subject to various regulations including GDPR and industry standards like ISO 27001.

Create the following compliance documentation:

1. Develop a Compliance Policy Statement (5-7 sentences) that outlines TechSecure Solutions' commitment to regulatory compliance. Include the purpose, scope, key principles, and responsibilities. (10 points)

Answer:

TechSecure Solution is a mid-size ssoftware development organization that handle sensitive customer data of individual in the European Union and beyond. TechSecure Solution is under key regulations such as the General Data Protection Regulation (GDPR), as well as international standards including ISO 27001 for information security management.

The purposes of the policy is to ensure the protection of customer sensitive data, safeguard business information confidentiality, integrity and availability. The scope of TechSecure Solution is is to encompassing all employees, contractors, third-party vendors, and any systems or processes involved in collecting, processing, storing, or transmitting data.

The principles include processing personal data lawfully, fairly, and transparently; limiting data collection to what is necessary

The Compliance Officer is responsible for implementing, monitoring, and reporting on compliance efforts. All employees are required to understand their compliance obligations and adhere to established policies and procedures.

2. Create a Compliance Monitoring Plan that includes at least five specific monitoring activities, their frequency, responsible parties, and how results will be documented. Present this in a table format. (10 points)

Answer:

Specific monitoring activities	Frequency	Responsible Parties	Results
Policies and Procedure Review	Annually	Compliance Officer	Policy review logs and updated version records
Access control audit	Quarterly	IT manager	Auddit report log
Employee Awareness training and education	Quarterly	Human Resources Manager or Compliance Officer	Training attendance sheet record
Incident management Review	Monthly	Information security team	Risk register and action taken to remediate the risk
Vendors and thrid paarty compliance review	Annually	Compliance Officer	Review findings in vendor assessment form

3. Design a Compliance Incident Response Procedure that outlines the steps to be taken when a potential compliance violation is identified. Include at least 6 steps with brief descriptions of each. (10 points)

Answer:

1. Identification and Reporting: once an employee identified a potential violation which can be detected through internal audit, such they must report immediately to the compliance officer. Report should include the date, time, individual or systems involved and any other evidence

2. Initial Assessment and classification: After the employee identified the incident to the compliance officer or the incident reponse team must evaluate the creditibility of the incident with 24 hours to determine the likelihood,and potential impact of the risk and the risk should be clasified as High, medium and low. It involves gathering evidence and deciding to escalates it to tr incident response team

3. Containment and Mitigation: once the incident is classified, we take immediate action to prevent further harm by isolating the affected systems to ensure a minimal disruption to business operation.

4. Investigation: once the risk is contained and isolated then we conduct a root cause analysis by the Incident response team.

5. Remediation: once investigation is done, we create an action plan addressing both the risk or the violations and preventing future occurrence.

6. Report and communication: report and notify the senior executive, the board or the audit committee depending on the severity of the incident, if violation involves data breach like GDPR, HIPAA, THE WE NOTIFY THE REGULATORY BODIES within the timeframes stated by the regulatory.

Part 2: Compliance Metrics and KPIs (25 points)

Effective compliance management requires measuring and reporting on key metrics. For this exercise, you will develop a set of compliance metrics and KPIs for TechSecure Solutions.

1. Identify and describe five key compliance metrics or KPIs that TechSecure Solutions should track. For each metric, explain what it measures, why it's important, how it should be calculated, and what the target or benchmark should be. (15 points)

Answer:

Metric	Explain what it measures	Why it's important	How it should be calculated	What the target or benchmark should be
Process Metric - Policy, procedures, standards, and regulations implementation	It is important as polices and regulations that is out of date can result to non compliance to such regulation as regulation (GDPR, ISO 270001) changes, organization are to update in their policies, procedure,	Documented policies, procedures and standards and regulations are are only important when been followed.	It can be measured through internal audit and monitoring.	There should be a range that represent the level of adherence to polices, procedures, standard and regulation such that if it drop below the range, it should be

	standard, and regulation.			flag immediately.
Risk Metric - Number of security incidents that happen over a period of time	It is measured by the number of security incident over a period of time depending on organization and it can be monthly, quarterly etc	It is important as the number of security incident that happen help test the controls in place.	The total number of incident that is documented or reported	All critical security incident remediated as soon ass detected.
Outcome Metric - GDPR Data breach incident	It is measured by the number of GDPR data breach of personal data	Due to the strict obligation of data protection by GDPR, it is important that TechSecure Solutions control prevent compliance failure	The total number of personal data breach monthly or quarterly	According to GDPR, it is mandatory to report any incident of data breach within 72 hours
Financial Metric - cost of compliance and non compliance	It is measured by the investment cost on training, audit or compliance tools against the financial losses from penalties to non compliance, incident etc	Ensuring compliance in place is more cost effective than paying fines in non compliance	It can be calculated by knowing the compliance investments cost over that of non compliance	Ensuring compliance in place can greatly reduces the cost expenses of TechSecure Solutions due to incident or penalties
Cultural Metric - Employee awareness training	It is measured by the employees particpation during security/incident awareness training	One of the major risk TechSecure might face is the human error, therefore security/incident awareness training can reduces incident like phishing attack, weak password, data handling, MFA etc	It can be calculated by the number of the employee who complete their training over the total number of the workforce	All Employee of TechSecure Solution are expected to complete a security awareness training quarterly, or annually

2. Design a mock-up of a quarterly compliance dashboard that would be presented to the executive team. Describe what information would be included, how it would be visualized, and why this information is valuable for executive decision-making. (10 points)

Answer:

Dashboard sections and visualization

A. Overall compliance status: the information included are the compliance rating, summary of KPI, compaeison of previous quarter.it will be visualize by light traffic indicator and high level scorecard which will provide the senior executive an immediate understanding of either the compliance is improving or declining and allows them to focus on the problem area

B. Control Environment: A robust control environment is essential for a strong compliance posture. This section on the compliance dashboard should display details such as the total number of controls; the number of controls tested, planned but not tested, and not planned; and key control test results, including the total number of key control tests conducted so far, controls operating effectively, not operating effectively, etc. Such information helps in identifying control weaknesses and gaps as well as prioritizing efforts and resources to address them.

Compliance Snapshot: This section provides a snapshot of compliance status by organization, including particular division, department, etc.; by area of compliance, which displays the compliance status with respect to relevant regulations such as PCI DSS, HIPAA, ISO 27001-2013, etc. This information helps to pinpoint areas of non-compliance at a quick glance for prompt action.

Compliance Issues: This section provides information on all compliance-related issues. These could be categorized by rating (critical, high, medium, and low), status (open, closed, pending approval), and type (control failure, data breach, deviation from policy, IT control failure).

Performance Metrics: Key performance indicators (KPIs) related to compliance should be displayed. Metrics such as the number of compliance incidents, resolution times, and adherence rates provide valuable insights into the compliance posture.

Audit Trails and Logs: Maintaining detailed audit trails and logs within the dashboard ensures transparency and accountability. This helps in tracing the history of compliance actions, making it easier to demonstrate compliance during audits.

Notifications and Alerts: These should be configurable to notify relevant stakeholders about upcoming deadlines, changes in regulations, or emerging compliance issues.

Real-Time Monitoring: Real-time data integration allows you to continuously monitor compliance activities and status. This helps in identifying and addressing issues as they arise, rather than after they have escalated.

Part 3: Compliance Audit Preparation (25 points)

TechSecure Solutions is preparing for an ISO 27001 certification audit in three months. As the Compliance Officer, you need to prepare the organization for this important audit.

1. Create a pre-audit checklist with at least 10 specific items that should be reviewed or prepared before the ISO 27001 audit. For each item, briefly explain its importance to the audit process. (15 points)

Answer:

1. The Scope: Audit usually start with defining scope of the certification and it and it should include which department, systems, location.

2. Review information security policy: it is important to have information security policy as it part of what is required by ISO 27001, so it is important that the policy is review, up-to-date, and aligned with business objectives

3. Risk Assessment and Risk Treatment: The risk assessment should be comprehensive, covering all relevant threats and vulnerabilities, and should be based on a clear and consistent methodology while risk treatment plan should be based on the results of the risk assessment and should include a clear justification for the selection of controls. Auditors will review these documents to confirm compliance

4. Verify the Statement of Applicability (SoA): this document is important during certification as it list controls and state whether they are implemented.

5. Conduct internal ISO 27001 Audit: ISO 27001 require that TechSecure Solutions must perform internal audit and show all relevant evidence as without the internal audit, certification cannot be granted

6. Management review meeting: Management review meeting and oversight is very important as it is a mandatory requirement

7. Security awareness training: it is important to keep records of employees security awareness training as this shows that employees are aware and well informed of their security responsibilities

8. Incident management records: it is important to show past incidents and how they were handled

9. Document Control: it is important to document control as auditor will check the policies, procedures on how they are being controlled

10. Prepare evidence for the Auditor: all document should be properly organized and presented when the auditor come for easy access and for smooth audit process.

2. Develop a communication plan for preparing employees for the upcoming audit. Include at least three different communication methods, the key messages for each, target audience, and timing. (10 points)

Answer:

During an audit session for ISO 27001 certification, it is important that the communication plan should address the 5 W's which are What, When, Whom, Who and How. Although TechSecure Solutions can communicate through internal, external and incident communication

A) What - to communicate

B) When - to communicate

C) Whom - to communicate

D) Who - shall communicate

E) How - to communicate

Communication Method	Key Messages	Target Audience	Timing
Email communication	Audit scope, objectives, expectation, responsibilities	All Employees	It should start between the range of 12weeks - 1 week before audit
Security awareness training session	ISO 27001 security awareness training sessions	All employees and senior management	9 -5 weeks before the audit
Departmental Meetings	Role based responsibilities such as who or how to respond to auditor questions	Departmental head and team member	2-5 weeks before the audit

Part 4: Compliance Program Evaluation (20 points)

Case Study: FinTech Innovations

FinTech Innovations is a financial technology company that has been in operation for five years. They provide payment processing services and financial management software to small and medium-sized businesses. The company has grown rapidly from 20 to 150 employees and now serves clients in multiple countries.

The company established a compliance program three years ago when they reached 50 employees. The program consists of:

• A part-time Compliance Officer (who also serves as the Legal Counsel)
• A set of compliance policies that were developed when the program was established
• Annual compliance training for all employees
• Quarterly compliance reports to the executive team
• Ad-hoc compliance monitoring activities

Recently, the company experienced a compliance incident where they failed to update their privacy policies to reflect new regulatory requirements in one of their operating regions. This resulted in a small fine and negative publicity. The CEO has asked for an evaluation of the current compliance program to identify areas for improvement.

Based on this case study, answer the following questions:

1. Evaluate FinTech Innovations' current compliance program using the seven elements of an effective compliance program as a framework. Identify at least three strengths and three weaknesses of their current approach. (10 points)

Answer:

Element of effective compliance	Strengths	Weaknesses
1. Written policies and procedures: Standards of conduct, ethics policies, and specific procedural guidance	● Fintech innovation already have an establish policies, they establish a compliance program three years ago when they reached 50 employees ● Policies guide employees behavior and regulatory compliance ● The fact that Fintech have a written policies previously show initial commitment to their formal compliance structure	● Policies was last update 3 years ago therefore doesn't reflect regulatory compliance ● The incident review that policy processes are weak control ● Despite operating in different regions, there is no evident of region based policies
Compliance leadership: Designated compliance officer and compliance committee with oversight authority	● A compliance officer role exits within Fintech ● Compliance oversight is assigned ● Quarterly compliance reports to the executive team	● Compliance officer role is part time ● The compliance officer also double as the legal counsel which can result in work overload ● Fintech growth was not match with expanded compliance leadership
Training and Education: Regular, comprehensive training programs for all employees and stakeholders	● Annual compliance training for all employees ● Training is formalized ● Fintech recognize that training and education for employees is one of it regulatory compliance program	● Training occur annually ● No evidence of training ● No mention of role based compliance training
Effective Communication: Open channels for reporting issues, including anonymous reporting options	● Quarterly compliance reports to the executive team ● Employees are informed of the compliance objectives through the training and education training annually ● Fintech established a well structures communication	● Communication is limited to executive team ● No regular updates on compliance to employee especially on regulatory changes ● No channels for questions and report
Monitoring and Audit: Regular assessment of	● Perform compliance monitoring and audit	● Ad-hoc compliance monitoring

compliance program effectiveness and risk area	activities ● Quarterly compliance reports	activities ● No internal audit ● L=lack of continuous monitoring lead to outdated policies
Enforcement and Discipline: Regular assessment of compliance program effectiveness and risk areas	● Policies contain employee behavioural expectation ● The executive attention to the incident shows enforcement ● Compliance program show some level of enforcement and discipline	● No enforcement for compliance violations ● Without enforcement, policy might not be taken seriously by employees ● No disciplinary procedures in the program
Response and prevention: Prompt investigation of issues and implementation of corrective actions	● Fintech acknowledged incident failure after it occurred ● Fintech paid for the fine and addresses the immediate issue ● The CEO requested for an evaluation which show improvement	● No system to detect regulatory changes in place ● Lack of control in place allowed the violation

2. Recommend five specific improvements to strengthen FinTech Innovations' compliance program. For each recommendation, explain the rationale and expected benefits. (10 points)

Answer:

a) Employ a full time compliance officer which should be different from the legal counsel role

Rationale: the current compliance officer is part time and serve as a legal counsel which can be work overload.

Benefit: employing a compliance officer role separated from a legal counsel is a best practise for compliance framework

b) Establish a process to track, review and implement new regulatory requirement in all operating region

Rationale: there is no updated policies thereby not meeting the regulation therefore causing fintech their recent fines

Benefits: reduction on fines, and updates to policies and procedures.

c) Improve monitoring and audit activities: instead of the ad-hoc monitoring their should be formal compliance monitoring and audit

Rationale: a formal compliance monitoring and audit help to detect the gaps before it become an incident

Benefits: early detection of control failures and report availability for auditors and regulators

d) Improve training, education and communication: security awareness training, education and communication should not be annually. It can be quarterly or as fintech decides.

Rationale: Annually training is not enough for fintech due to the growing rate

Benefits: reduction in human error risk and strong culture of compliance

e) Established enforcement and disciplinary measures in Fintech: an established procedures for non compliance should be stated

Rationale: the cuurent program does not describe enforcement.

Benefits: employees take compliance more seriously as there are consequences stated in policies.

Submission Guidelines:

1. Save this document with the filename format:
GRC101_Week4_Lab_FirstName_LastName.docx
2. Submit your completed lab assignment through the course learning management system.
3. Due date: [Instructor to specify]

Grading Rubric:

- **Part 1: Compliance Documentation Development - 30 points**
- **Part 2: Compliance Metrics and KPIs - 25 points**
- **Part 3: Compliance Audit Preparation - 25 points**
- **Part 4: Compliance Program Evaluation - 20 points**

Total: 100 points